

Modern SOC Operasyonları ve Detection Engineering

MITRE ATT&CK, Atomic Red Team ve
Wazuh ile Tehdit Avcılığı■

EVOLUTION OF ENDPOINT SECURITY: AV vs. EDR

Legacy AV	Modern EDR & Telemetry
İmza Tabanlı (Signature-Based)	Davranış Tabanlı (Behavior-Based)
Sadece Kötü Amaçlı Yazılım (Malware Only)	Tüm Sistem Aktiviteleri (Telemetry & Events)
Kör Noktalar (Blind Spots)	Derin Görünürlük (Deep OS Visibility)
Statik Engelleme (Static Blocking)	Sürekli Avcılık (Continuous Threat Hunting)

Geleneksel AV ölüdür. Modern saldırganlar meşru araçları kullanır (Living off the Land). Bu yüzden **Sysmon** gibi araçlarla işletim sistemi seviyesinde **Telemetry** toplamaya ihtiyacımız var.

Savaş Alanı Haritası: MITRE ATT&CK

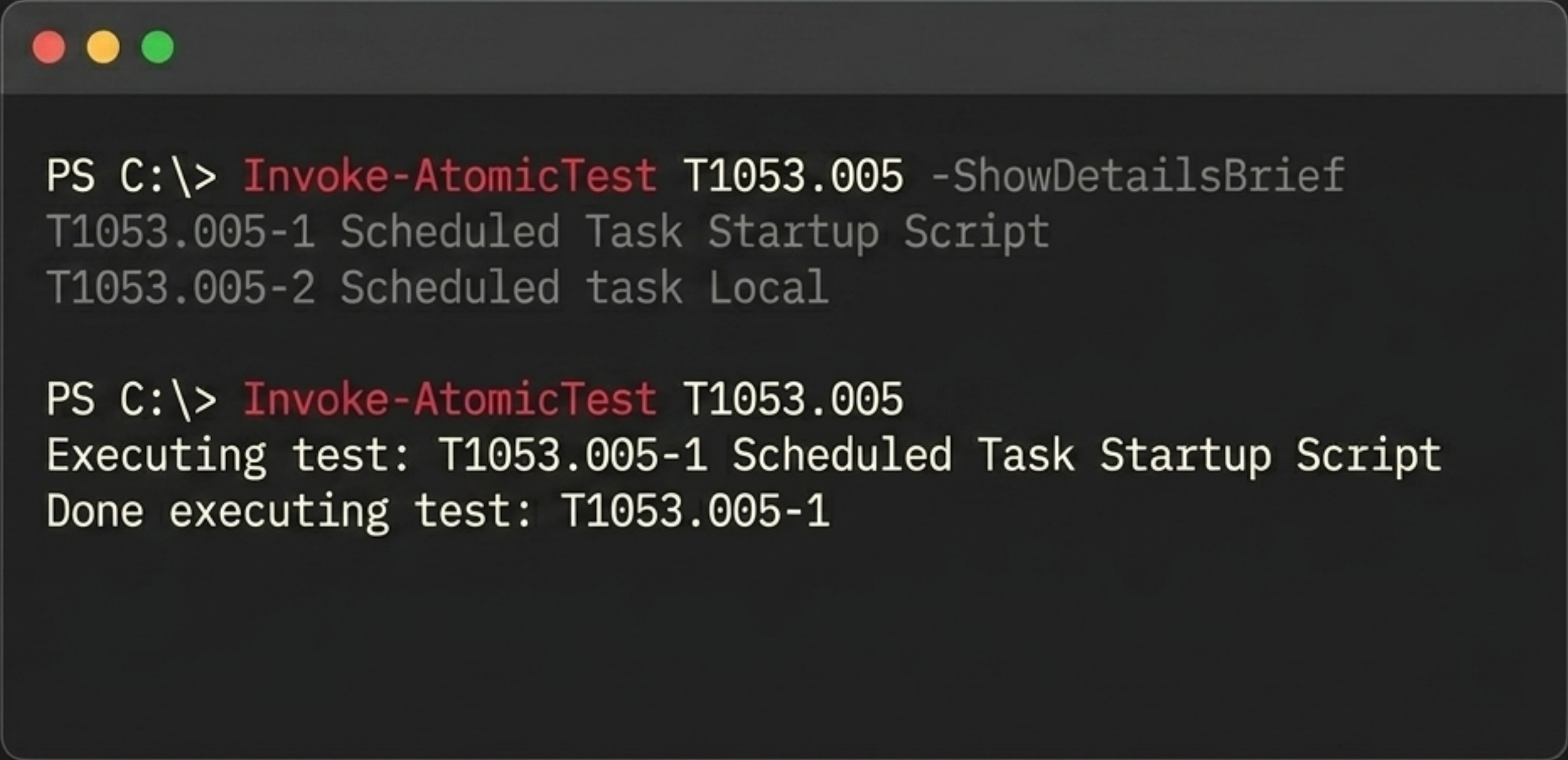
Execution	Persistence	Privilege Escalation	
	T1053.005 Scheduled Task		
		T1574.001 DLL Side-Loading	
T1053.005 Execution Block			

Düşmanın TTP'lerini
(Tactics, Techniques,
and Procedures)
standartlaştırır.

Ne tür saldırıları tespit
edip edemediğimizi
ölçmemizi sağlar.

Adım 1: Saldırı Simülasyonu

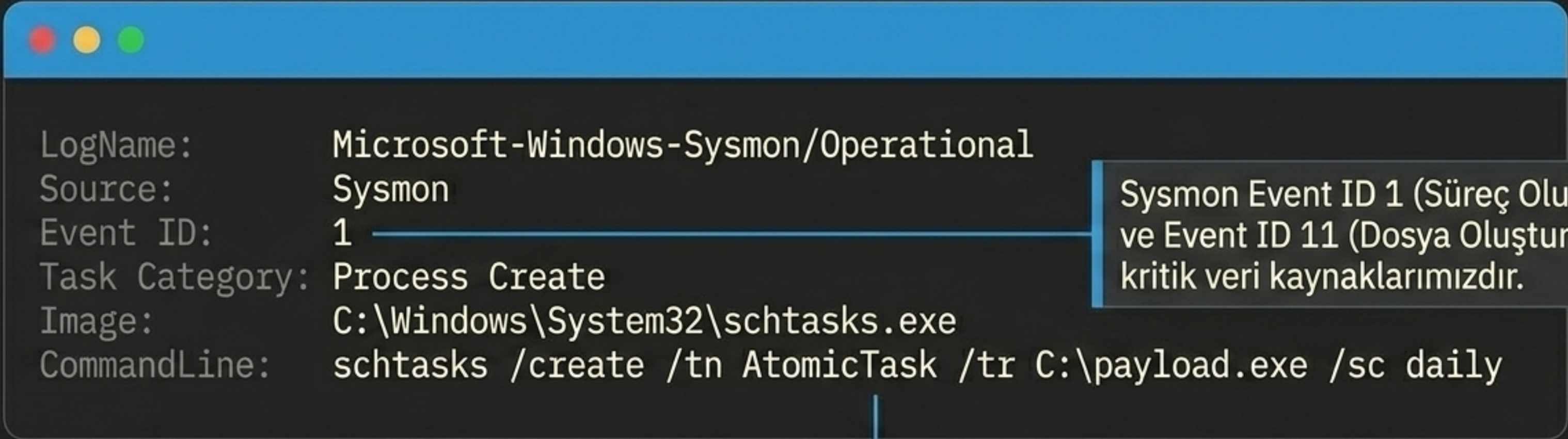
T1053.005 (Scheduled Task) tekniğini tetikledik. Hedef: Zararlı bir görevin sisteme zamanlanmış olarak eklenmesi.



```
PS C:\> Invoke-AtomicTest T1053.005 -ShowDetailsBrief
T1053.005-1 Scheduled Task Startup Script
T1053.005-2 Scheduled task Local

PS C:\> Invoke-AtomicTest T1053.005
Executing test: T1053.005-1 Scheduled Task Startup Script
Done executing test: T1053.005-1
```


Adım 2: İşletim Sistemi Görünürlüğü (Sysmon)



A Sysmon event log entry for a process creation. The entry is displayed in a window with a blue title bar and three colored window control buttons (red, yellow, green) on the left. The text is as follows:

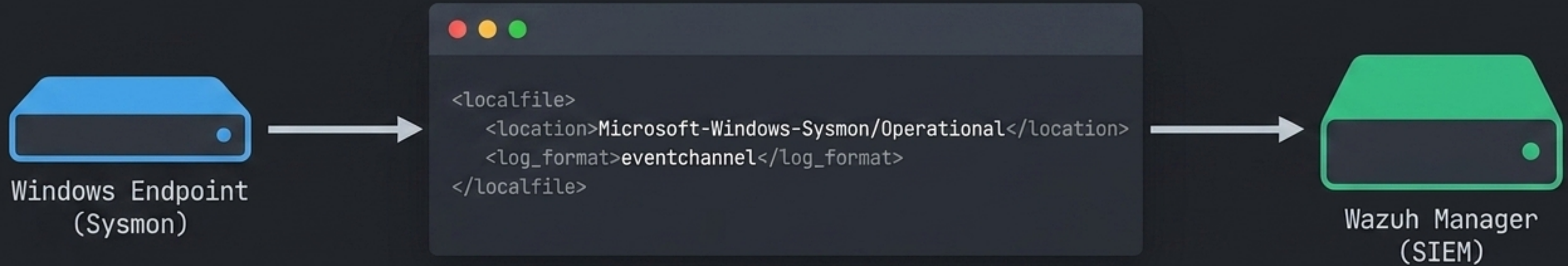
LogName:	Microsoft-Windows-Sysmon/Operational
Source:	Sysmon
Event ID:	1
Task Category:	Process Create
Image:	C:\Windows\System32\schtasks.exe
CommandLine:	schtasks /create /tn AtomicTask /tr C:\payload.exe /sc daily

Sysmon Event ID 1 (Süreç Oluşturma) ve Event ID 11 (Dosya Oluşturma) en kritik veri kaynaklarımızdır.

Saldırganın çalıştırdığı tam komut çekirdek (kernel) seviyesinde yakalandı.

Adım 3: Veri Toplama (Wazuh Agent)

Endpoint üzerindeki Wazuh ajanı, Sysmon loglarını okur ve analiz edilmek üzere merkezi SIEM platformuna iletir.



Adım 4: Detection Engineering

```
<rule id="115001" level="10">
```

```
  <if_group>windows</if_group>
```

```
  <field name="win.eventdata.ruleName">technique_id=T1053</field>
```

```
  <description>A Newly Scheduled Task has been Detected</description>
```

```
  <mitre><id>T1053</id></mitre>
</rule>
```

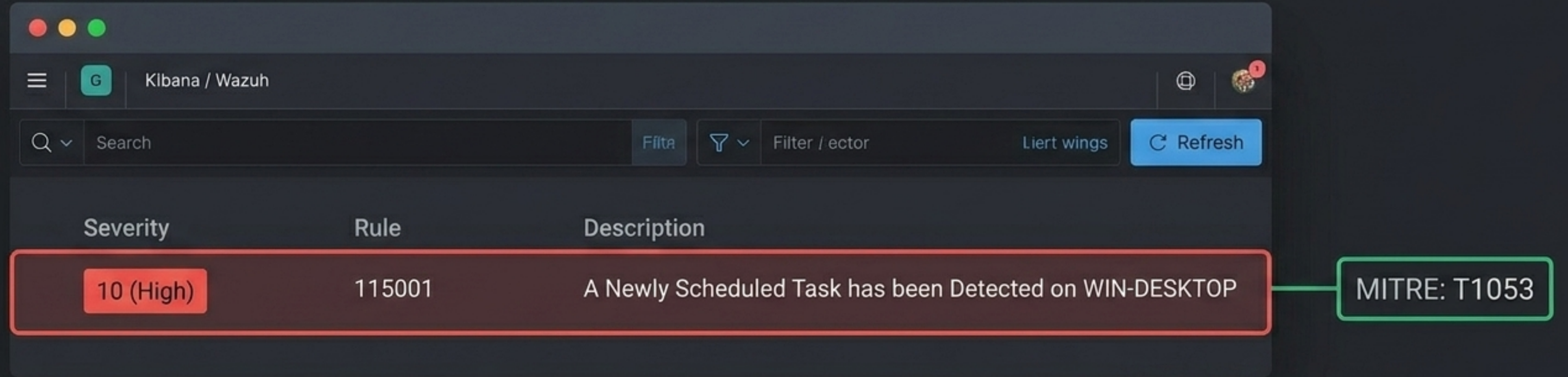
Filtre: Sadece Windows loglarında ara.

Mantık: Sysmon verisi içinde Scheduled Task izini (Regex/Match) bul.

Zenginleştirme: Uyarıyı doğrudan MITRE ATT&CK framework'üne bağla.

Adım 5: SOC Görünürlüğü ve Uyarı

Ham log + Tespit Mantığı = Aksiyon Alınabilir İstihbarat. SOC analisti artık tehdidin ne olduğunu, nerede olduğunu ve hangi MITRE tekniği ile eşleştiğini saniyeler içinde görebilir.

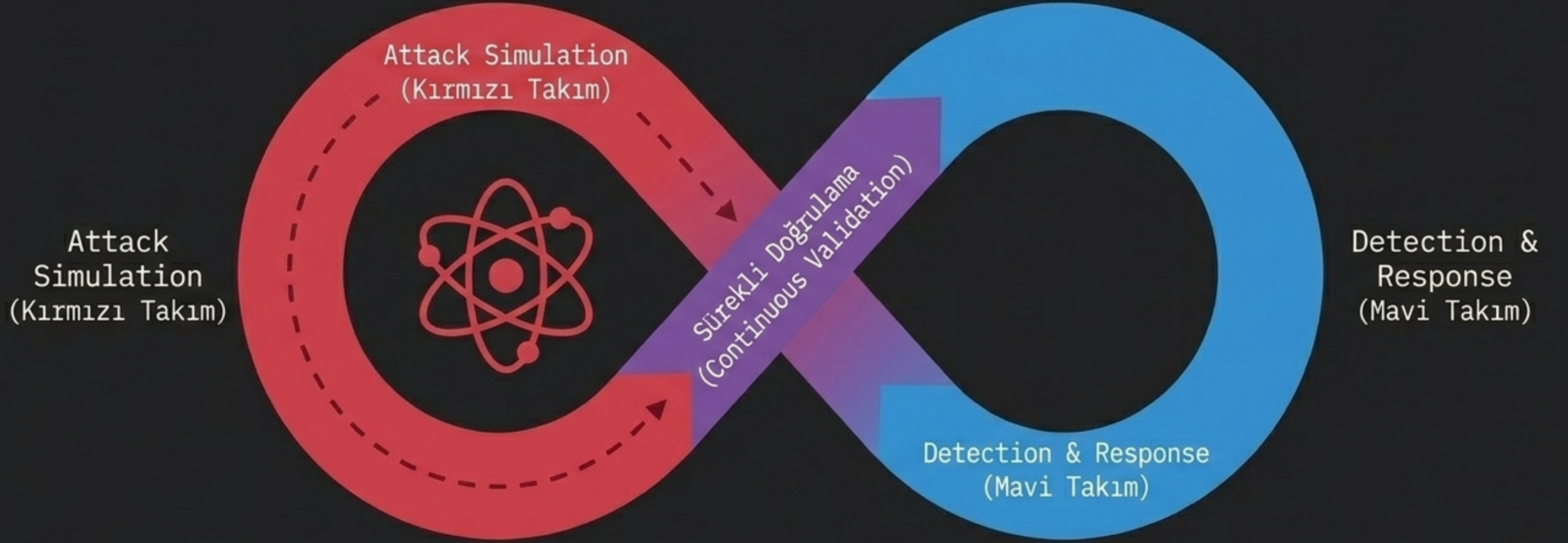


The screenshot shows the Kibana / Wazuh interface. The top navigation bar includes a hamburger menu, a green 'G' icon, and the text 'Kibana / Wazuh'. Below the navigation bar is a search bar with a magnifying glass icon and the text 'Search'. To the right of the search bar are buttons for 'Filtre', 'Filter / ector', 'Liert wings', and a blue 'Refresh' button. The main content area displays a table with three columns: 'Severity', 'Rule', and 'Description'. The first row of the table is highlighted with a red border and contains the following data: '10 (High)' in the Severity column, '115001' in the Rule column, and 'A Newly Scheduled Task has been Detected on WIN-DESKTOP' in the Description column. To the right of the table, a green box contains the text 'MITRE: T1053', which is connected to the description of the alert by a green line.

Severity	Rule	Description
10 (High)	115001	A Newly Scheduled Task has been Detected on WIN-DESKTOP

MITRE: T1053

Purple Teaming ve Atomic Red Team



Kötü adamları beklemeyiz. Güvenlik altyapımızı test etmek için MITRE ATT&CK tekniklerini 5 dakika içinde, güvenli bir şekilde simüle ederiz.



Test edilmemiş savunma, savunma değildir.

Modern SOC operasyonları, tehditleri varsaymak yerine kanıtlamayı gerektirir. Sürekli simüle edin, sürekli tespit edin.